

GMX · SECURITY REVIEW

# GMX

# Reader Review.

A security review of Reader Review.

| CLIENT | PROJECT       | AUDITORS | AUDIT WINDOW                | FINAL REPORT    |
|--------|---------------|----------|-----------------------------|-----------------|
| GMX    | Reader Review | Guardian | August 13 – August 18, 2025 | August 25, 2025 |

§ 00

# Contents.

13 pages — overview, confidence ranking, scope, 4 findings, disclaimer, and about Guardian.

|      |                          |       |
|------|--------------------------|-------|
| § 01 | Overview                 | P. 03 |
| § 02 | Confidence Ranking       | P. 04 |
| § 03 | Scope & Classifications  | P. 05 |
|      | Files in Scope           | P. 06 |
| § 04 | Findings                 | P. 07 |
|      | Main Review · 4 findings | P. 08 |
| § 05 | Disclaimer               | P. 12 |
| § 06 | About Guardian           | P. 13 |

§ 01

# Overview.

Guardian reviewed Reader Review across a single review round. The final report includes 1 Low, 3 Informational findings.

|                             |                                       |
|-----------------------------|---------------------------------------|
| AUDIT FIRM                  | REPOSITORY                            |
| Guardian                    | gmx-io/gmx-synthetics                 |
| CLIENT                      | METHODOLOGY                           |
| GMX                         | Smart contract · Manual · Main Review |
| PROJECT                     | MAIN REVIEW COMMIT                    |
| Reader Review               | 57d2cbc0f87f                          |
| PREPARED BY                 |                                       |
| Guardian                    |                                       |
| AUDIT WINDOW                |                                       |
| August 13 – August 18, 2025 |                                       |
| FINAL REPORT                |                                       |
| August 25, 2025             |                                       |

## 1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

|                     |                |                     |                 |                      |
|---------------------|----------------|---------------------|-----------------|----------------------|
| 1                   | 2              | 3                   | 4               | 5                    |
| VERY LOW CONFIDENCE | LOW CONFIDENCE | MODERATE CONFIDENCE | HIGH CONFIDENCE | VERY HIGH CONFIDENCE |

## 1.2 Findings at a Glance

| SEVERITY                     | TOTAL | PENDING | ACK | PARTIAL | RESOLVED |
|------------------------------|-------|---------|-----|---------|----------|
| <span>■</span> Critical      | 0     | 0       | 0   | 0       | 0        |
| <span>■</span> High          | 0     | 0       | 0   | 0       | 0        |
| <span>■</span> Medium        | 0     | 0       | 0   | 0       | 0        |
| <span>■</span> Low           | 1     | 0       | 1   | 0       | 0        |
| <span>■</span> Informational | 3     | 0       | 3   | 0       | 0        |
| All severities               | 4     | 0       | 4   | 0       | 0        |

## § 02

# Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

| CONFIDENCE RANKING                               | DEFINITION AND RECOMMENDATION                                                                                                                                                                                               | RISK PROFILE                                                                              |
|--------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|
| <b>5 Very High Confidence</b><br><b>ASSIGNED</b> | Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit. | 0 High/Critical findings and few Low/Medium severity findings.                            |
| <b>4 High Confidence</b>                         | Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.    | 0-1 High/Critical findings per engagement week and little to no Medium severity findings. |
| <b>3 Moderate Confidence</b>                     | Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.                                                            | Some High/Critical findings, with various Medium severity findings.                       |
| <b>2 Low Confidence</b>                          | Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.                                                                     | Over 6 High and Critical findings across the engagement.                                  |
| <b>1 Very Low Confidence</b>                     | The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.                                                                           | Over 12 High and Critical findings across the engagement.                                 |

§ 03

# Scope & Classifications.

Guardian reviewed Reader Review in `gmx-io/gmx-synthetics`.

## 3.1 Severity Matrix

|            | IMP · HIGH | IMP · MED | IMP · LOW |
|------------|------------|-----------|-----------|
| LIK · HIGH | Critical   | High      | Medium    |
| LIK · MED  | High       | Medium    | Low       |
| LIK · LOW  | Medium     | Low       | Low       |

IMPACT · HIGH  
Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM  
Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW  
Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH  
Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM  
Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW  
Unlikely to ever occur in production.

# Files in Scope.

| FILE                             | NSLOC | TOTAL |
|----------------------------------|-------|-------|
| No files were recorded in scope. |       |       |

§ 04

# Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

| ID          | TITLE                                 | CATEGORY         | SEVERITY      | STATUS       | PAGE  |
|-------------|---------------------------------------|------------------|---------------|--------------|-------|
| MAIN REVIEW |                                       |                  |               |              |       |
| L-01        | Unused Structs                        | Superfluous Code | LOW           | ACKNOWLEDGED | p. 8  |
| I-01        | Function Without Logic                | Best Practices   | INFORMATIONAL | ACKNOWLEDGED | p. 9  |
| I-02        | Inconsistent Function Parameter Names | Informational    | INFORMATIONAL | ACKNOWLEDGED | p. 10 |
| I-03        | Missing Params In NatSpec             | Best Practices   | INFORMATIONAL | ACKNOWLEDGED | p. 11 |

LOW **L-01**

ACKNOWLEDGED

# Unused Structs

|          |                                                                                                                                                                                                                                                                                                                                             |
|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CATEGORY | Superfluous Code                                                                                                                                                                                                                                                                                                                            |
| LOCATION | <a href="https://github.com/GuardianOrg/gmx-synthetics-gmxreader-team1/blob/57d2cbc0f87fce751f5d62140fc7406ee390d1f/contracts/reader/ReaderPricingUtils.sol#L32C1-L46C6">https://github.com/GuardianOrg/gmx-synthetics-gmxreader-team1/blob/57d2cbc0f87fce751f5d62140fc7406ee390d1f/contracts/reader/ReaderPricingUtils.sol#L32C1-L46C6</a> |
| REVIEW   | Main Review                                                                                                                                                                                                                                                                                                                                 |

## DESCRIPTION

The `ReaderPricingUtils` contract contains `PositionInfo` and `GetPositionInfoCache` structs similar to those in `ReaderPositionUtils`. However, the structs in `ReaderPricingUtils` are outdated and not used anywhere, so they can be removed.

## RECOMMENDATION

Consider removing unused structs.

## RESOLUTION

Status: Acknowledged.

INFORMATIONAL **I-01**

ACKNOWLEDGED

# Function Without Logic

CATEGORY Best Practices

LOCATION <https://github.com/gmx-io/gmx-synthetics/blob/67a99599e152c8301cc4b30ecfb64f4ef7ce56f2/contracts/reader/KeeperReader.sol#L28-L37>

REVIEW Main Review

## DESCRIPTION

The `getLiquidatablePositions` function has no logic implemented.

## RECOMMENDATION

Consider removing it / commenting it out or implementing the logic.

## RESOLUTION

Status: Acknowledged.

INFORMATIONAL **I-02**

ACKNOWLEDGED

# Inconsistent Function Parameter Names

|          |                                                                                                                                                                                                                                                                                                       |
|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CATEGORY | Informational                                                                                                                                                                                                                                                                                         |
| LOCATION | <a href="https://github.com/GuardianOrg/gmx-synthetics-gmxreader-team1/blob/57d2cbc0f87fce751f5d62140fc7406ee390d1f/contracts/reader/Reader.sol#L252">https://github.com/GuardianOrg/gmx-synthetics-gmxreader-team1/blob/57d2cbc0f87fce751f5d62140fc7406ee390d1f/contracts/reader/Reader.sol#L252</a> |
| REVIEW   | Main Review                                                                                                                                                                                                                                                                                           |

## DESCRIPTION

In the Reader contract, the `getPnlToPoolFactor` function uses `marketAddress`, while other functions such as `getMarketInfo`, `getExecutionPrice`, and `getSwapPriceImpact` use `marketKey` as a parameter.

## RECOMMENDATION

Consider using `marketKey` in the `getPnlToPoolFactor` function as well for consistency.

## RESOLUTION

Status: Acknowledged.

INFORMATIONAL **I-03**

ACKNOWLEDGED

# Missing Params In NatSpec

CATEGORY Best Practices

LOCATION <https://github.com/gmx-io/gmx-synthetics/blob/67a99599e152c8301cc4b30ecfb64f4ef7ce56f2/contracts/position/PositionUtils.sol#L315-L329>

REVIEW Main Review

## DESCRIPTION

There are some missing params in the NatSpec of the `isPositionLiquidatable` function. The same holds true for the `IsPositionLiquidatableCache`.

## RECOMMENDATION

Consider adding the params to the NatSpec.

## RESOLUTION

Status: Acknowledged.

## § 05

# Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

# About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

**\$45B+**DIGITAL ASSETS UNDER  
REVIEW**200+**

ENGAGEMENTS COMPLETED

**500+**CRITICAL & HIGH FINDINGS  
REPORTED

Reach us at [audits@guardianaudits.com](mailto:audits@guardianaudits.com).